

Report - Progetto S11L5

PowerShell, Analisi IoC, Nmap e SQL Injection su Wireshark

Indice

Obiettivo del Progetto

Esercizio 1 - PowerShell su Windows Server

Step 1 - Comando dir in PowerShell ISE e CMD

Step 2 - ping, cd e ipconfig a confronto

Step 3 - Get-Alias dir

Step 4 - netstat -h e netstat -r

Step 5 - netstat -abno e verifica PID nel Task Manager

Step 6 - Svuotare il Cestino con Clear-RecycleBin

Esercizio 2 - Analisi IoC con Sandbox any.run

Albero dei Processi (Process Tree)

Tecniche MITRE ATT&CK rilevate

Bonus 1 - Ricognizione di Rete con Nmap

man nmap - Manuale e opzioni principali

nmap localhost e nmap -A -T4 192.168.64.0/24

nmap scanme.nmap.org

Bonus 2 - Analisi SQL Injection con Wireshark

Ricostruzione dell'attacco - Follow HTTP Stream

Conclusioni

Obiettivo del Progetto

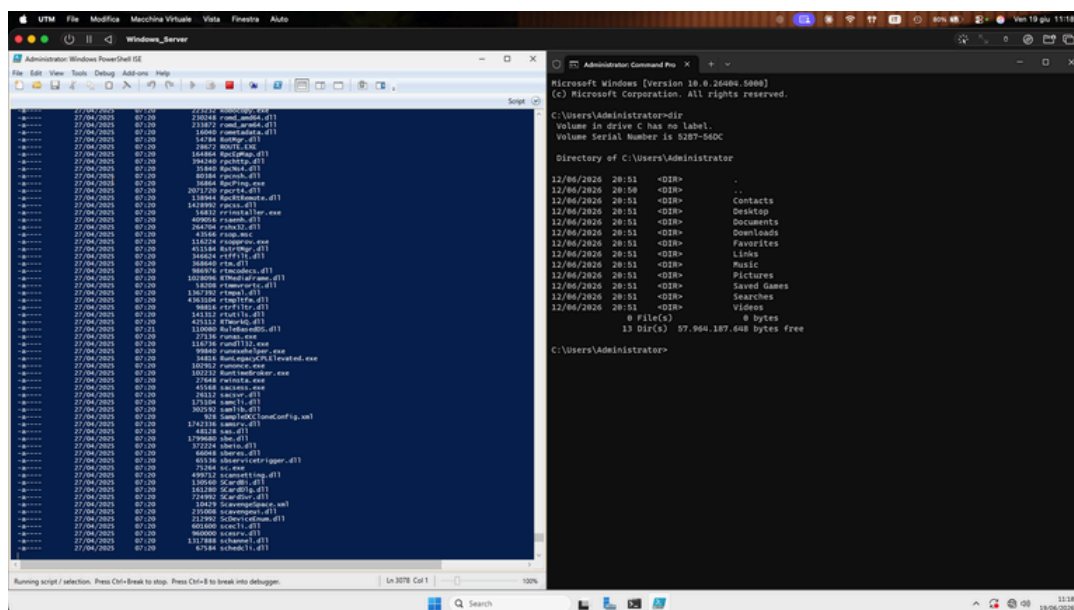
Il progetto S11L5 integra quattro aree pratiche della cybersecurity affrontate durante il modulo: l'utilizzo di PowerShell come shell avanzata su Windows Server, l'analisi di un campione malware reale tramite sandbox, la ricognizione di rete con Nmap e l'analisi forense di un attacco SQL Injection su traffico catturato con Wireshark. Ogni parte produce evidenze concrete di come gli strumenti si usano in un contesto di difesa e analisi.

Esercizio 1 - PowerShell su Windows Server

L'esercizio si svolge su Windows Server 2022 con PowerShell ISE aperto affiancato al Prompt dei comandi (CMD). L'obiettivo è confrontare i due ambienti: CMD è la shell classica di Windows, mentre PowerShell è una shell orientata agli oggetti con cmdlet nella forma verbo-sostantivo (es. Get-ChildItem, Get-Alias). Molti comandi CMD funzionano in PowerShell tramite alias, ma con funzionalità estese.

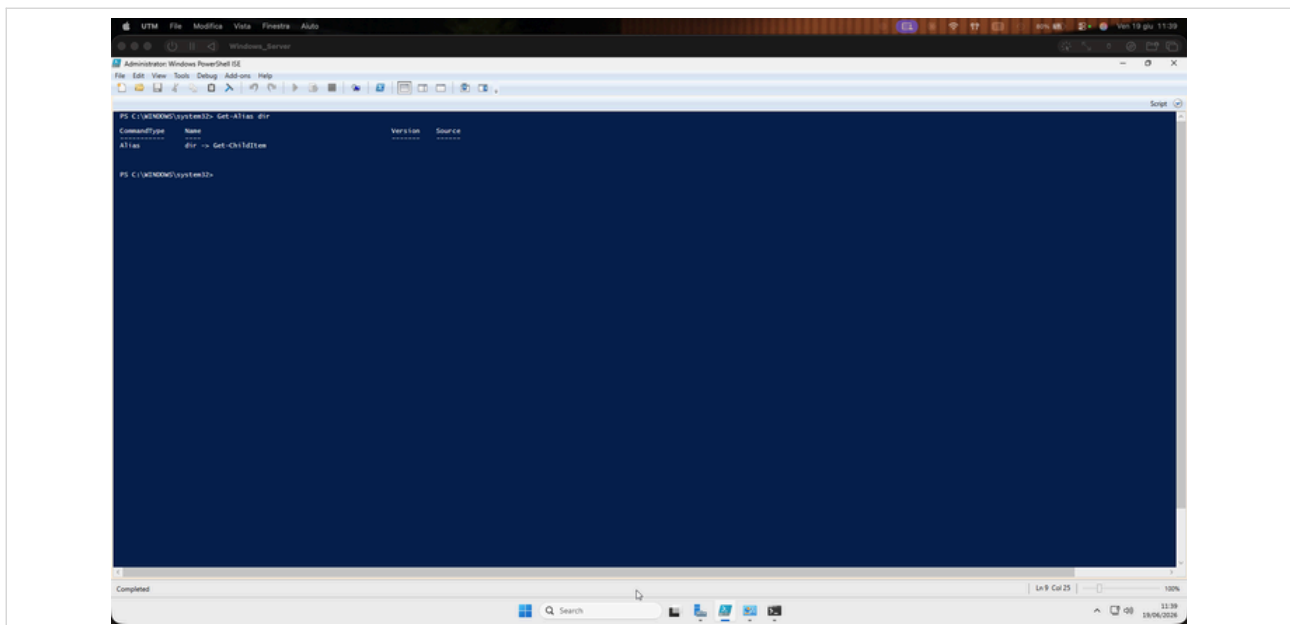
Step 1 - Comando dir in PowerShell ISE e CMD

Il comando **dir** viene eseguito in entrambi gli ambienti. In PowerShell ISE il pannello superiore mostra l'output di `dir C:\Windows\System32`: una lista di migliaia di file .exe e .dll di sistema, che scorre per oltre 8000 righe. In CMD, `dir C:\Users\Administrator` mostra le 13 cartelle standard del profilo utente (Desktop, Downloads, Documents...) senza file.



Step 2 - ping, cd e ipconfig a confronto

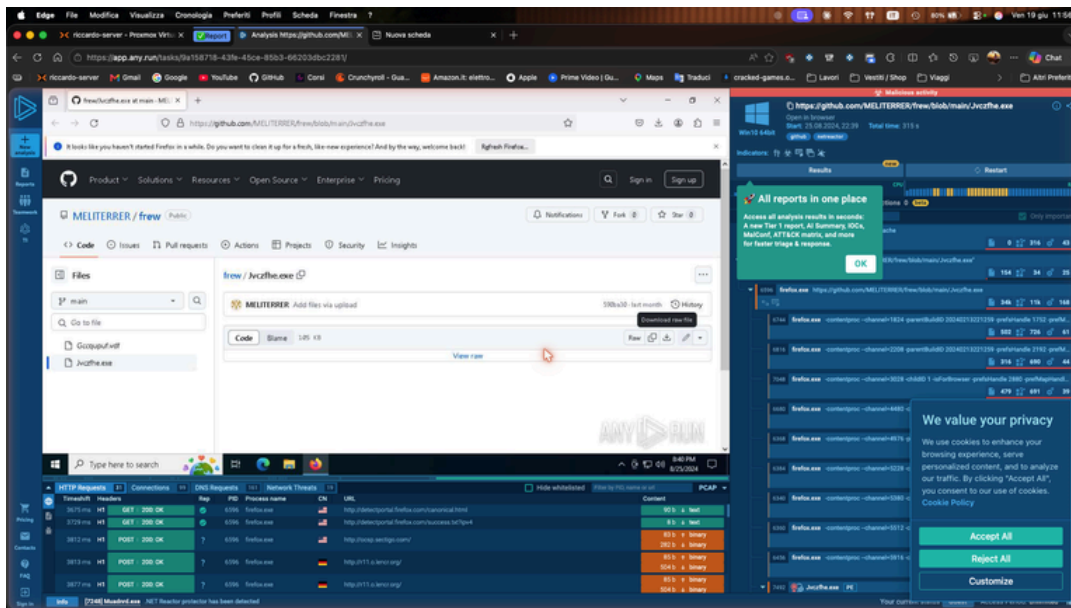
I comandi **ping google.com**, **cd Desktop** e **ipconfig** vengono eseguiti in parallelo nei due ambienti. I risultati sono identici nei valori ma con differenze sintattiche: in PowerShell il prompt aggiorna il path completo dopo il cd (PS C:\Users\Administrator\Desktop>), mentre CMD mostra solo il path relativo. Il ping risponde a 142.251.27.101 con TTL=109, latenza media 37ms, 0% packet loss. **ipconfig** mostra IP 192.168.50.10, subnet 255.255.255.0, gateway 192.168.50.1.



D: Cosa mostra Get-Alias dir?

Step 4 - netstat -h e netstat -r





Riepilogo IoC (Indicators of Compromise)

Indicatore	Valore	Tipo
File originale	Jvczfhe.exe (105 KB)	Malware dropper
Sorgente	github.com/MELITERRER/frew/blob/main/Jvczfhe.exe	URL di distribuzione
File droppato	Muadnrd.exe	Payload secondario
Ambiente	Windows 10 64-bit, 25/08/2024	Target
Protettore	.NET Reactor	Offuscamento
LOLBin usato	InstallUtil.exe (PID 5152)	Process injection
Evasione	cmd.exe /c timeout 21	Time-based delay
Crash osservati	WerFault.exe x2 (PID 1356, 7584)	Possibile anti-debug
Network Threats	19 rilevate	Traffico malevolo
DNS Requests	161	Ricognizione/C2

Albero dei Processi (Process Tree)

La catena di esecuzione registrata dalla sandbox segue questo schema:

```
firefox.exe (PID 6596)
naviga a github.com/MELITERRE/frew → scarica Jvczfhe.exe

Jvczfhe.exe (PID 7492) [MALICIOUS]
cmd.exe /c timeout 21 & exit ← evasione temporale
InstallUtil.exe (PID 5152) ← LOLBin per process injection
WerFault.exe (PID 1356) ← crash / anti-debug

Muadnrd.exe (PID 7824) [MALICIOUS - dropped]
cmd.exe /c timeout 21 & exit
WerFault.exe (PID 7584)

Muadnrd.exe (PID 7248) [MALICIOUS - seconda istanza]
.NET Reactor protector detected
```

Tecniche MITRE ATT&CK rilevate

Tecnica	ID	Descrizione
LOLBin - InstallUtil	T1218.004	Uso di InstallUtil.exe legittimo per eseguire codice malevolo senza scrivere file su disco
Obfuscated Files	T1027	.NET Reactor cifra e offusca il bytecode .NET per impedire il reverse engineering
Time-Based Evasion	T1497.003	timeout 21 introduce un ritardo prima dell'esecuzione per eludere sandbox con timeout brevi

D: Perché il malware usa InstallUtil.exe invece di eseguire direttamente?

R: InstallUtil.exe è un binario legittimo di Windows (.NET Framework) firmato da Microsoft. Usarlo per eseguire codice malevolo (tecnica LOLBin) permette di bypassare whitelist di applicazioni e alcuni antivirus che si fidano dei processi firmati da Microsoft. Il malware inietta il payload nel processo InstallUtil già in esecuzione, rendendo il comportamento malevolo più difficile da attribuire.

Bonus 1 - Ricognizione di Rete con Nmap

Nmap (Network Mapper) è lo scanner di rete più diffuso nel mondo della cybersecurity. L'esercizio si svolge sulla VM CyberOps (analyst@secOps) e prevede l'ispezione del manuale, la scansione del localhost, della rete locale e del target ufficiale scanme.nmap.org.

man nmap - Manuale e opzioni principali

Il manuale di nmap descrive lo strumento come "Network exploration tool and security / port scanner". Le opzioni principali usate nell'esercizio:

Opzione	Significato
-A	Abilita OS detection, version detection, script scanning e traceroute
-T4	Timing aggressivo (scala 0-5): scan più veloce, adatto a reti veloci
-sV	Version detection: identifica la versione del servizio su ogni porta


```
NAME
  nmap - Network exploration tool and security / port scanner

SYNOPSIS
  nmap [Scan Type...] [Options] (target specification)

DESCRIPTION
  Nmap ("Network Mapper") is an open source tool for network exploration and security auditing. It was designed to rapidly scan large networks, although it works fine against single hosts. Nmap uses raw IP packets in novel ways to determine what hosts are available on the network, what services (application name and version) those hosts are offering, what operating systems (and OS versions) they are running, what type of packet filters/firewalls are in use, and dozens of other characteristics. While nmap is commonly used for security audits, many systems and network administrators find it useful for routine tasks such as network inventory, managing service upgrade schedules, and monitoring host or service uptime.

  The output from Nmap is a list of scanned targets, with supplemental information on each depending on the options used. Key among that information is the "interesting ports table". That table lists the port number and protocol, service name, and state. The state is either open, filtered, closed, or unfiltered. Open means that an application on the target machine is listening for connections/packets on that port. Filtered means that a firewall, filter, or other network obstacle is blocking the port so that Nmap cannot tell whether it is open or closed. Closed ports have no application listening on them, though they could open up at any time. Ports are classified as unfiltered when they are responsive to Nmap's probes, but Nmap cannot determine whether they are open or closed. Nmap reports the state combinations open|filtered and closed|filtered when it cannot determine which of the two states describe a port. The port table may also include software version details when version detection has been requested. When an IP protocol scan is requested (-sO), Nmap provides information on supported IP protocols rather than listening ports.

  In addition to the interesting ports table, Nmap can provide further information on targets, including reverse DNS names, operating system guesses, device types, and MAC addresses.

  A typical Nmap scan is shown in Example 1. The only Nmap arguments used in this example are -A, to enable OS and version detection, script scanning, and traceroute; -T4 for faster execution; and then the hostname.

  Example 1. A representative Nmap scan

  # nmap -A -T4 scanme.nmap.org

  Nmap scan report for scanme.nmap.org (74.207.244.221)
  Host is up (0.02% latency).
  DNS record for 74.207.244.221: 1180-221.members.linode.com
  Not shown: 995 closed ports
  PORT      STATE SERVICE      VERSION
  22/tcp    open  ssh          OpenSSH 5.3p1 Debian 3ubuntu7 (protocol 2.0)
  |_ ssh-hostkey: 1024 8d:60:f1:7c:ca:b7:3d:8a:06:67:54:9d:69:09:b9:dd (DSA)
  |_ 2048 79:f8:09:ac:d4:e2:32:42:10:49:d3:bd:20:82:05:ec (RSA)
  80/tcp    open  http         Apache httpd 2.2.14 ((Ubuntu))
  |_ http-title: Go ahead and ScanMe!
  646/tcp   filtered ldp
  1720/tcp  filtered H.323/Q.931

  Manual page nmap(1) line 1 (press h for help or q to quit)
```

nmap localhost e nmap -A -T4 192.168.64.0/24

nmap localhost (127.0.0.1) rileva una sola porta aperta: **22/tcp ssh**. **Nmap 7.97** scansiona 1 host in 0.03 secondi. **nmap -A -T4 192.168.64.0/24** scansiona l'intera subnet (256 indirizzi) e trova 2 host attivi in 70 secondi:

Host	Porta	Servizio	Note
192.168.64.1	53/tcp	domain	Gateway NAT di UTM (DNS)
192.168.64.1	5000/tcp	rtsp	AiTunes/950.7.1 (Apple RTSP, Mac host)
192.168.64.24	22/tcp	ssh	OpenSSH 10.0 protocol 2.0

```
analyst@secops: ~$ nmap localhost
Starting Nmap 7.97 ( https://nmap.org ) at 2020-06-19 10:08 +0000
Nmap scan report for localhost (127.0.0.1)
Host is up (0.00023s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 999 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh

Nmap done: 1 IP address (1 host up) scanned in 0.83 seconds

analyst@secops: ~$ nmap -A -T4 192.168.64.0/24
Starting Nmap 7.97 ( https://nmap.org ) at 2020-06-19 10:09 +0000
Stats: 0:00:12 elapsed; 0 hosts completed (0 up), 256 undergoing Ping Scan
Parallel DNS resolution of 256 hosts. Timing: About 0.78% done
Nmap scan report for 192.168.64.1
Host is up (0.00034s latency).
Not shown: 997 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
53/tcp    open  domain       (generic dns response: NOTIMP)
5000/tcp  open  rtsp         AiTunes/950.7.1
|_ _rtsp-methods: ERROR: Script execution failed (use -d to debug)
|_ fingerprint:strings:
|_ FourOHfourRequest:
|_ HTTP/1.1 403 Forbidden
|_ Content-Length: 0
|_ Server: AiTunes/950.7.1
|_ X-Apple-ProcessingTime: 6
|_ X-Apple-RequestReceivedTimestamp: 79950910
GetRequest:
|_ HTTP/1.1 403 Forbidden
|_ Content-Length: 0
|_ Server: AiTunes/950.7.1
|_ X-Apple-ProcessingTime: 5
|_ X-Apple-RequestReceivedTimestamp: 79945802
HTTPOptions:
|_ HTTP/1.1 403 Forbidden
|_ Content-Length: 0
|_ Server: AiTunes/950.7.1
|_ X-Apple-ProcessingTime: 4
|_ X-Apple-RequestReceivedTimestamp: 79950900
RTSPRequest:
|_ RTSP/1.0 403 Forbidden
|_ Content-Length: 0
```

scanme.nmap.org (45.33.32.156) e' il target ufficiale messo a disposizione da Nmap per esercitazioni. La scansione base (senza -A) dura 14.57 secondi e identifica 4 porte aperte:

Porta	Stato	Servizio	Note
22/tcp	open	ssh	Accesso remoto sicuro
80/tcp	open	http	Web server (pagina di benvenuto Nmap)
9929/tcp	open	nping-echo	Tool di test pacchetti Nmap
31337/tcp	open	Elite	Porta storica degli hacker (Easter egg Nmap)

```

File Edit View Terminal Tabs Help
CyberOps Workstation Arm
Applications Xfce Terminal
Terminal - analy@secops:~

File Edit View Terminal Tabs Help

SP:127.0.0.1:55551:SYN_RECV [FIN:65535] [SUBMIT] INDIVIDUALLY:=====
SP:Port7800-TCIP-Vx7:8791x720d6f195fTime6d315479maagch64-unknown-linux-g
SP:uxz(RTSRequest_BE,"RTSP/1.1.0x20403x20f0sbidderinContent-Length:Vx2
SP:001vInServer:Vx2081vInSeq:9501.7v.1vInX-Apple-ProcessingTime:Vx2071vIn
SP:Apple-RequestReceivedInStamp:Vx2079950808vInXvIn"X[getRequest_BE
SP:,"HTTP/1.1Vx204031x20f0sbidderinContent-Length:Vx2001vInServer:Vx2081
SP:1vInTimes/9501.7v.1vInX-Apple-ProcessingTime:Vx203vInX-Apple-RequestRec
SP:ceivedInStamp:Vx2079950808vInXvIn"X[getRequest_BE,"HTTP/1.1Vx2040
SP:3vInServer:Vx2081vInSeq:9501.7v.1vInX-Apple-ProcessingTime:Vx2079950808
SP:1vInX-Apple-ProcessingTime:Vx2081vInX-Apple-RequestReceivedInStamp:Vx
SP:2079950808vInXvIn"X[FourOFourRequest_BE,"RTSP/1.1.0x20403x20f0sbid
SP:derinContent-Length:Vx2001vInServer:Vx2081vInSeq:9501.7v.1vInX-Apple
SP:-ProcessingTime:Vx203vInX-Apple-RequestReceivedInStamp:Vx2079950808v
SP:3vInXvIn"X[getRequest_BE,"RTSP/1.1.0x204031x20f0sbidderinContent-Len
SP:g:gh:Vx2001vInServer:Vx2081vInTimes/9501.7v.1vInXSeq:Vx20421x200PTJON5v1v
SP:InX-Apple-ProcessingTime:Vx203vInX-Apple-RequestReceivedInStamp:Vx207
SP:9950808vInXvIn"X];

Nmap scan report for 192.168.64.24
Host is up (0.0035s latency).
Not shown: 999 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
OpenSSH 10.0 (protocol 2.0)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (2 hosts up) scanned in 70.02 seconds

[analy@secops ~]$ nmap -sS 192.168.64.24
Starting Nmap 7.97 ( https://nmap.org ) at 2024-06-19 10:19 +0800
Stats: 0:00:00 elapsed; 0 hosts completed (1 up); 1 undergoing Connect Scan
Connect Scan Timing: About 54.77% done; ETC: 10:19 (0:00:07 remaining)
Stats: 0:00:11 elapsed; 0 hosts completed (1 up); 1 undergoing Connect Scan
Connect Scan Timing: About 72.94% done; ETC: 10:19 (0:00:04 remaining)
Nmap scan report for 192.168.64.24 (192.168.64.24)
Host is up (0.19% latency).
Other addresses for 192.168.64.24 (not scanned): 2048:3c01:f03c:51ff:fe1b:b02f
Not shown: 999 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
91329/tcp open  nping-echo
91327/tcp open  Elite

Nmap done: 1 IP address (1 host up) scanned in 14.57 seconds
[analy@secops ~]$

```

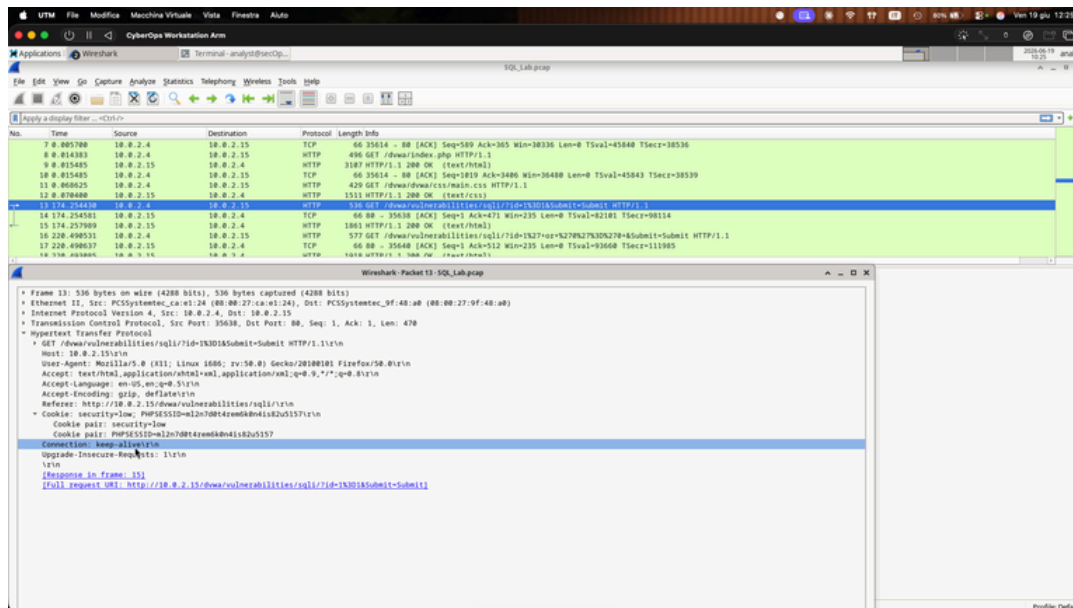
D: Cosa indica la porta 31337 su scanme.nmap.org?

R: La porta 31337 (leet speak per 'eleet') e' una porta storica della cultura hacker degli anni '90. Nmap la include intenzionalmente su [scanme.nmap.org](https://nmap.org) come easter egg. In contesti reali, la presenza di questa porta aperta su un host sconosciuto sarebbe un segnale d'allarme: e' associata a backdoor e trojan storici come Back Orifice.

Bonus 2 - Analisi SQL Injection con Wireshark

Il file **SQL_Lab.pcap** si trova in ~/lab.support.files/ sulla VM CyberOps. Contiene traffico HTTP catturato durante un attacco SQL Injection su **DVWA** (Damn Vulnerable Web Application), un'applicazione web intenzionalmente vulnerabile usata per la formazione. Il server target e' 10.0.2.15 (Apache/2.4.18 Ubuntu), il client attaccante e' 10.0.2.4 (Firefox su Linux). La sicurezza di DVWA e' impostata su 'low'.

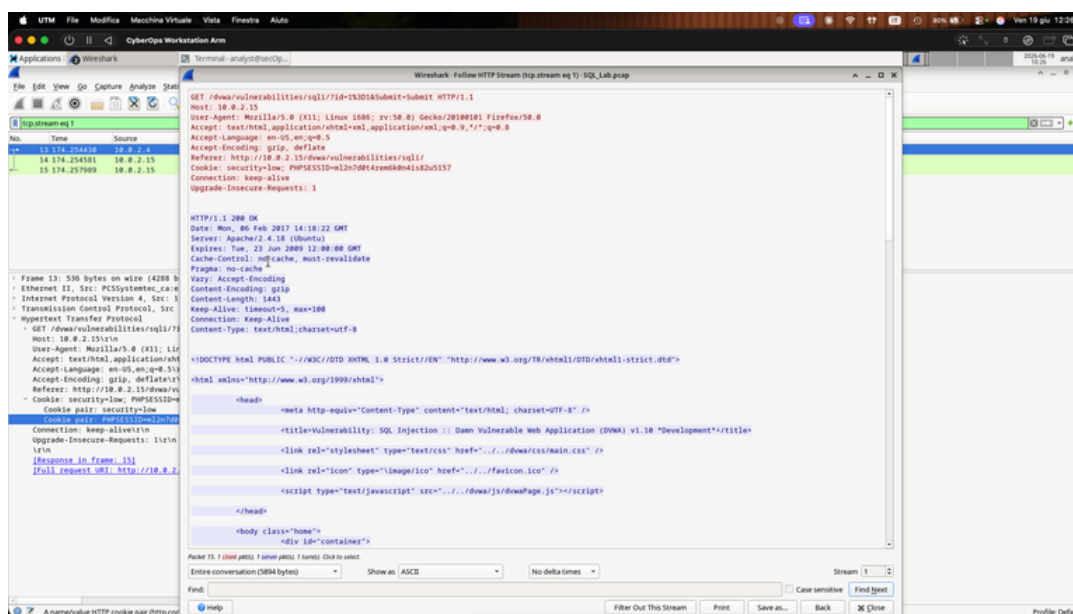
```
[analyst@secops ~]$ ls
Desktop  Downloads  e.pcap  lab.support.files  second_drive
[analyst@secops ~]$ cd lab.support.files/
[analyst@secops lab.support.files]$ ls
SQL_Lab.pcap  applicationX_in_epoch.log  confidential.txt  elk_services  instructor  logstash-tutorial.log  mininet_services  pcaps  sample.img  scripts
apache_in_epoch.log  attack_scripts  cyops.mn  h2_dropbear.banner  letter_to_grandma.txt  malware  openssl_lab  pox  sample.img_SHA256.sig
[analyst@secops lab.support.files]$
```



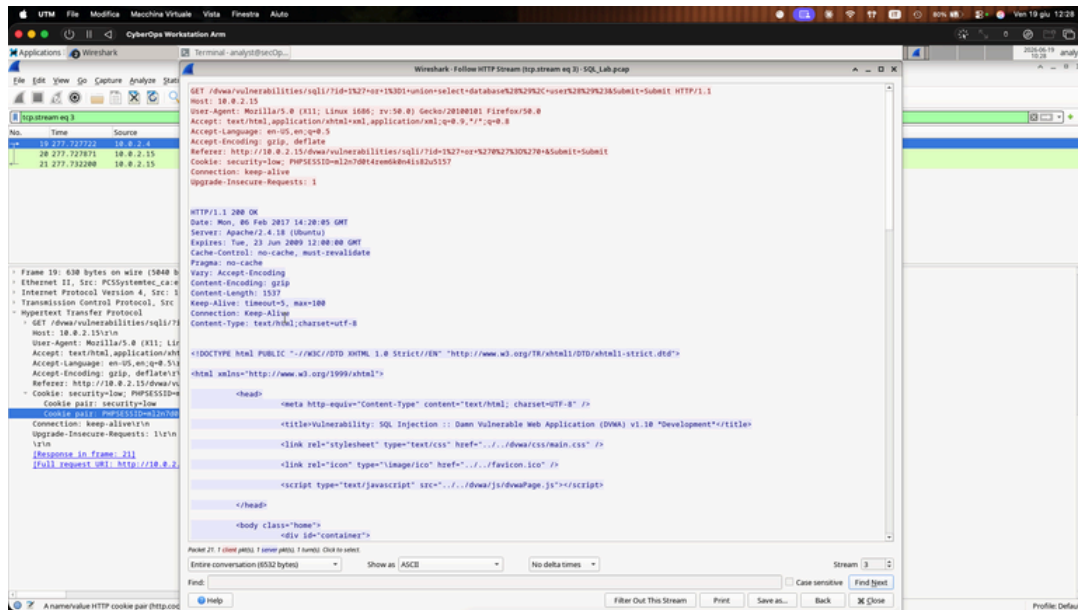
Ricostruzione dell'attacco - Follow HTTP Stream

Applicando **Follow HTTP Stream** sui frame chiave si ricostruisce l'intera progressione dell'attacco UNION-based SQL Injection in 5 fasi:

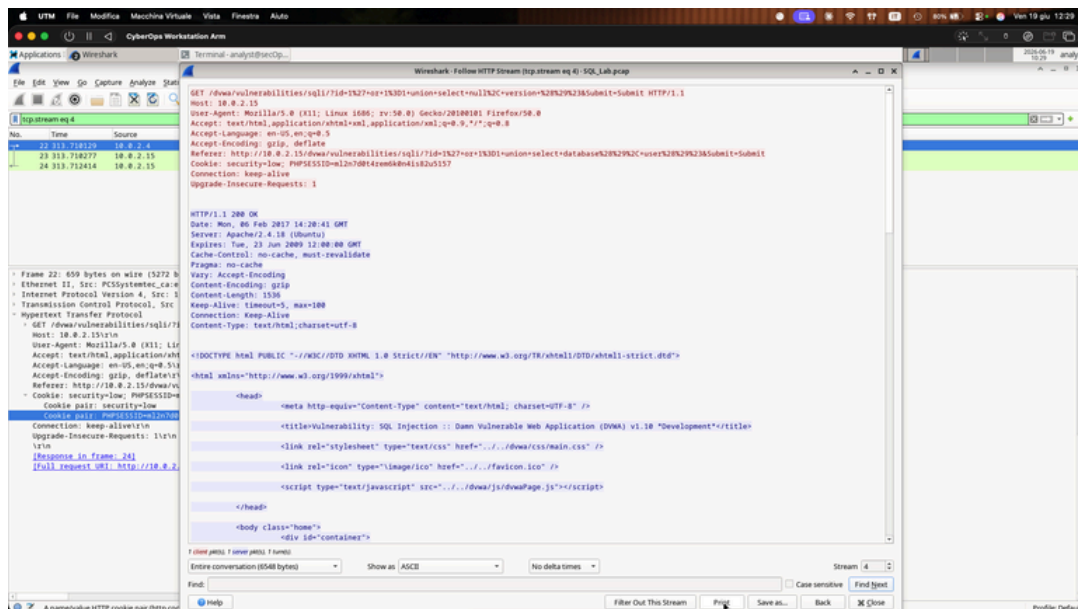
Stream 1 (Frame 13) - Probe iniziale: GET /dvwa/vulnerabilities/sqli/?id=1%3D1&Submit=Submit - Il parametro id riceve '1=1' (URL-encoded). Risposta: HTTP 200 OK, Server Apache/2.4.18 Ubuntu, pagina DVWA caricata correttamente. Questo conferma che il parametro id e' passato direttamente alla query SQL senza sanitizzazione.



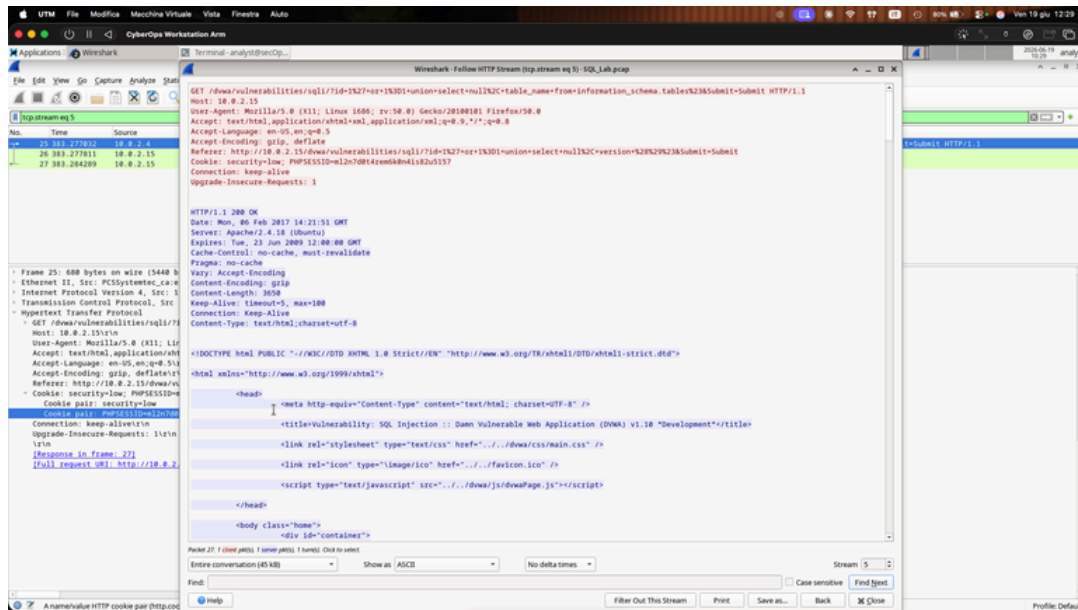
Stream 3 (Frame 19) - Estrazione DB e utente: id=1' or 1=1 union select database(),user()# - Il payload chiude la stringa SQL con un apostrofo, aggiunge una condizione sempre vera e inietta una UNION SELECT per estrarre il nome del database corrente e l'utente MySQL. Risposta: 200 OK, Content-Length 1537 (leggermente piu' grande del probe iniziale).



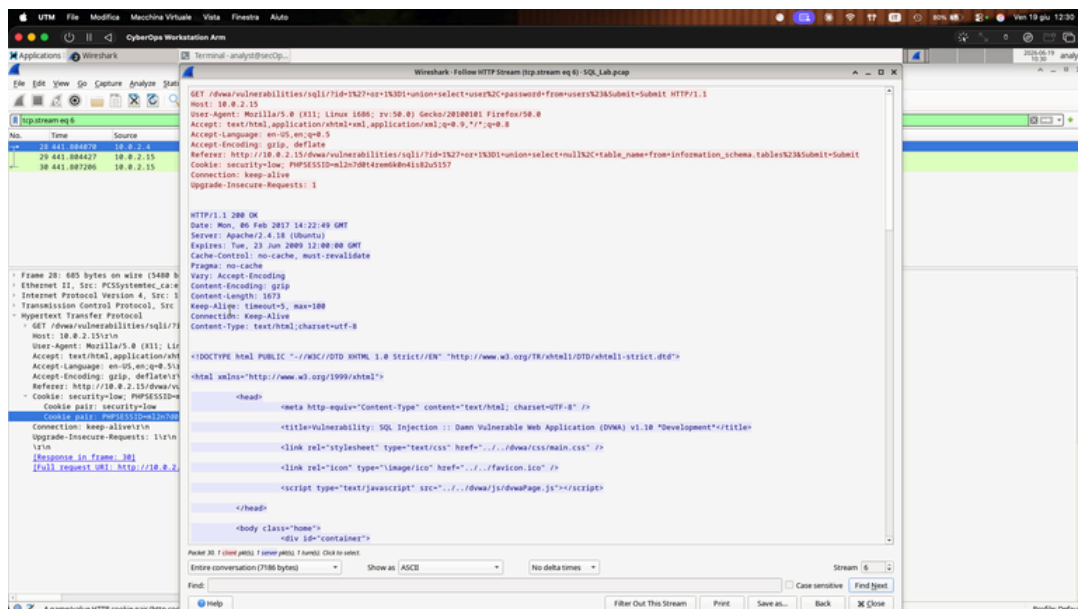
Stream 4 (Frame 22) - Versione MySQL: id=1' or 1=1 union select null,version()# - Nuova UNION SELECT per estrarre la versione del database server. Utile all'attaccante per scegliere exploit specifici per la versione di MySQL installata.

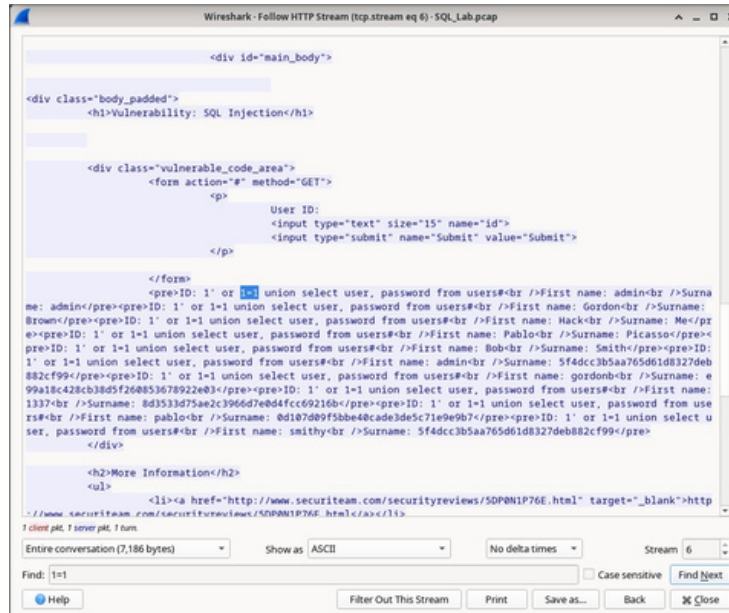


Stream 5 (Frame 25) - Enumerazione tabelle: id=1' or 1=1 union select null,table_name from information_schema.tables# - Query su information_schema.tables per elencare tutti i nomi di tabella del database. La risposta e' di 45 KB (Content-Length 3650 nella risposta compressa), molto piu' grande delle precedenti: indica un gran numero di tabelle restituite.



Stream 6 (Frame 28) - Estrazione credenziali: id=1' or 1=1 union select user,password from users# - Payload finale: ora che l'attaccante conosce il nome della tabella users, estrae direttamente username e hash delle password. Risposta: 200 OK, Content-Length 1673. Gli hash estratti sono in formato MD5.





Riepilogo progressione attacco SQL Injection

Fase	Frame	Payload (decoded)	Obiettivo
1 - Probe	13	id=1=1	Verifica vulnerabilita'
2 - DB +User	19	1' or 1=1 union select database(),user())#	Nome DB e utente MySQL
3 - Version	22	1' or 1=1 union select null,version())#	Versione MySQL
4 - Tables enum	25	1' or 1=1 union select null,table_name from information_schema.tables#	Elenco di tutte le tabelle
5 - Credentials	28	1' or 1=1 union select user,password from users#	Username e hash password

D: Come si previene un attacco SQL Injection come questo?

R: La difesa principale sono le Prepared Statements (query parametrizzate): il valore di 'id' viene passato come parametro separato dalla query, quindi un apostrofo nel valore non può rompere la struttura SQL. Ulteriori misure: input validation (accettare solo interi per un campo id), WAF (Web Application Firewall) che blocca pattern come UNION SELECT, privilege minimization (l'utente DB non deve avere accesso a information_schema), e non esporre messaggi di errore SQL al client.

Conclusioni

Il progetto ha coperto quattro aree fondamentali della cybersecurity pratica. PowerShell si è rivelato uno strumento molto più potente di CMD grazie al sistema di alias e cmdlet orientati agli oggetti, con netstat e Clear-RecycleBin che dimostrano come la gestione del sistema avvenga tramite una sintassi uniforme verbosostantivo. L'analisi IoC su any.run ha mostrato le tecniche di evasione moderne: .NET Reactor per l'offuscamento, InstallUtil come LOLBin e ritardi temporali per sfuggire alle sandbox. Nmap ha confermato la sua versatilità nella ricognizione, dal singolo host alla subnet completa fino a un target remoto reale. Infine, l'analisi del pcap SQL Injection ha reso visibile come un attacco UNION-based si sviluppa in 5 passi incrementali, dai permessi di lettura fino all'estrazione delle credenziali.